

# Атака PMKID (clientless) на WPA2-PSK

Аудит Wi-Fi на собственном оборудовании • Kali Linux • airgeddon

## 1. Контекст и правовая рамка

Работа выполняется в рамках курса «Информационная безопасность автоматизированных систем». Все действия проводятся **на собственном / подконтрольном оборудовании**: домашняя точка доступа RT-XXXX-XXXX (роутер [маршрутизатор], Ростелеком / [производитель скрыт]) и личный смартфон в роли эталонной цели. Для чужого оборудования потребовалось бы письменное разрешение владельца; в РФ неправомерный доступ квалифицируется по ст. 272 УК РФ.

Цель работы: **оценить применимость PMKID-атаки** к своей сети — можно ли получить материал для офлайн-подбора пароля без участия клиентов, и разобрать, от чего зависит успех такой атаки.

Целевая сеть: **RT-XXXX-XXXX**, BSSID AA:BB:CC:DD:EE:FF, WPA2-CCMP PSK, диапазон 2.4 ГГц, канал «авто» (за сессию наблюдались 7 → 3). Реальный ключ и пароль администратора в отчёте не приводятся.

## 2. Теория: что такое PMKID простыми словами

Пароль Wi-Fi по воздуху не передаётся никогда. Обе стороны независимо превращают парольную фразу в 256-битный ключ **PMK** (Pairwise Master Key) функцией **PBKDF2** (намеренно медленной, чтобы затруднить перебор). PMK зависит только от пароля и имени сети (SSID) и с устройства не уходит.

**PMKID** (PMK Identifier) — односторонний отпечаток: HMAC-SHA1 от PMK, привязанный к MAC-адресам точки и клиента. Роутер вкладывает его в первый кадр рукопожатия (EAPOL M1) ради быстрого переподключения. Отпечаток необратим — восстановить PMK из него нельзя, только перебором.

Идея атаки: PMKID роутер отдаёт добровольно при первой ассоциации, **без клиентов и без деаутентификации**. Имея PMKID и оба MAC-адреса, атакующий офлайн перебирает пароли: пароль → PMK → расчётный PMKID → сравнение с пойманным. Ключевая оговорка: PMKID — **необязательная функция**; если точка его не вкладывает или обнуляет — брать нечего.

## 3. Стенд и инструменты

|          |                                                                                                    |
|----------|----------------------------------------------------------------------------------------------------|
| Хост:    | Windows + VirtualBox 7.2.x -> гость Kali Linux                                                     |
| Ядро:    | 6.12.38 LTS (iw phy -> есть режим * monitor)                                                       |
| Адаптер: | Alfa AWUS036AC, чип RTL8812AU (USB 0bda:8812)<br>интерфейс за сессию получил имя wlan1 (не wlan0!) |
| Софт:    | airgeddon 12.0, hcxdump 7.1.2 (2026 ZeroBeat),<br>hcxpcapngtool, aircrack-ng suite                 |

## 4. Ход работы

### 4.1. Подготовка интерфейса

Адаптер за эту сессию был назван системой **wlan1** (определили по permaddr XX:XX:XX:...).

Перевод в монитор и проверка:

```
sudo airmon-ng check kill
sudo ip link set wlan1 down
sudo iw dev wlan1 set type monitor
sudo ip link set wlan1 up
iw dev wlan1 info      # -> type monitor
```

### 4.2. Разведка цели

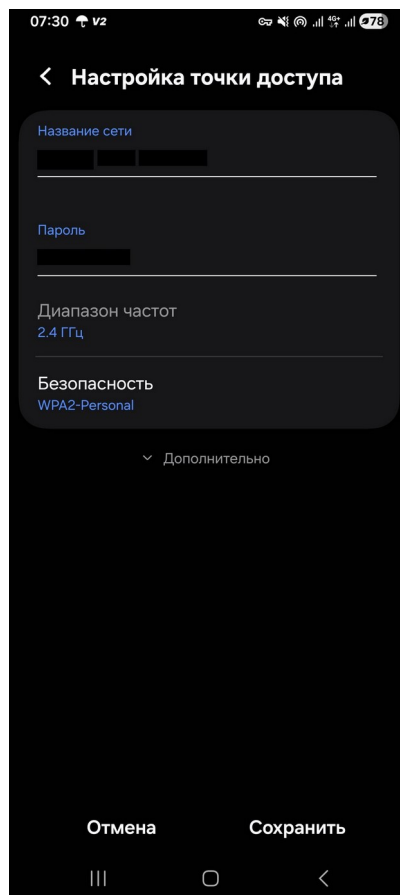
Штатный скан hcxdumptool (`--rcascan=active`) на этом драйвере ходил только по каналам 6 и 11 и **свою точку не увидел** (она была на канале 7). Пассивный обзор через aircrackedon «Explore for targets» (airodump по всем каналам) сразу нашёл RT-XXXX-XXXX с сигналом -35 — актуальный канал 7, позднее роутер перескочил на 3.

### 4.3. Активная PMKID-атака и её провал

Через aircrackedon (Handshake/PMKID → «Захват PMKID») запускался hcxdumptool. Он видел цель и слал запросы ассоциации, но валидный PMKID не извлекался — **два захода (45 и 100 секунд) провалились**. Показательно: hcxdumptool в справке предупреждает «Do not use virtual machines or emulators» — активная инъекция плохо работает через VirtualBox + RTL8812AU.

### 4.4. Контрольный эксперимент — ключевой момент

Чтобы понять, кто виноват — роутер (не отдаёт PMKID) или стенд (не может снять) — провели контроль на **заведомо подходящей цели**: мобильная точка телефона ([тестовый телефон], WPA2-Personal, 2.4 ГГц).



Настройки эталонной точки: 2.4 ГГц, WPA2-Personal — корректно для контроля

PMKID не снялся и с телефона. Вывод: проблема в стенде (VM + драйвер), а не в прошивке роутера. Этот шаг **уберёт от ложного вывода** «роутер Ростелеком защищён от PMKID»: проверив только роутер, мы бы ошиблись. Методологический урок — менять по одной переменной и иметь эталон.

#### 4.5. Захват handshake (обходной путь)

Раз активный метод не работает, переключились на пассивный захват рукопожатия (airgeddon → «Захват Handshake»). Первый заход (деаут mdk4, 20 с) провалился — клиент не успел переподключиться. Второй (деаут aireplay, 60 с, плюс ручное выключение/включение Wi-Fi на телефоне) дал результат: airgeddon отчитался о захвате handshake и, по его оценке, PMKID. Файл: /root/handshake-AA:BB:CC:DD:EE:FF.cap.

### 5. Строгая проверка захвата (hcxpcapngtool)

Файл лежит в /root, поэтому читается только под root (sudo):

```
sudo hcxpcapngtool -o /root/hash.hc22000 \
    "/root/handshake-AA:BB:CC:DD:EE:FF.cap"
sudo cat /root/hash.hc22000
```

```
~: zsh — Konsole
Новая вкладка  Разделить окно
Копировать  Вставить  Поиск...

EAPOL ANONCE error corrections (NC).....: not detected
EAPOL M1 messages (total).....: 1
EAPOL M2 messages (total).....: 1
EAPOL M3 messages (total).....: 1
EAPOL M4 messages (total).....: 1
EAPOL M4 messages (zeroed NONCE).....: 1
EAPOL pairs (total).....: 2
EAPOL pairs (best).....: 1
EAPOL pairs written to 22000 hash file...: 1 (RC checked)
EAPOL M3IE2 (authorized - ANONCE from M3): 1
packet read error.....: 1

Information: limited dump file format detected!
This file format is a very basic format to save captured network data.
It is recommended to use PCAP Next Generation dump file format (or pcapng for short) instead. The PCAP Next Generation dump file format is an attempt to overcome the limitations of the currently widely used (but very limited) libpcap (cap, pcap) format.
https://www.wireshark.org/docs/wsug_html_chunked/AppFiles.html#ChAppFilesCaptureFilesSection
https://github.com/pcapng/pcapng

Information: radiotap header is missing!
Radiotap is a de facto standard for 802.11 frame injection and reception. The radiotap header format is a mechanism to supply additional information about frames, from the driver to userspace applications.
https://www.radiotap.org/

Warning: too many deauthentication/disassociation frames detected!
That can cause that an ACCESS POINT change channel, reset EAPOL TIMER, renew ANONCE and set PMKID to zero. This could prevent to calculate a valid EAPOL MESSAGE PAIR, to get a valid PMKID or to decrypt the traffic.

Information: missing frames!
This dump file does not contain undirected probe request frames.
An undirected probe request may contain information about the PSK. It always happens if the capture file was cleaned or it could happen if filter options are used during capturing.
That makes it hard to recover the PSK.
https://github.com/ZerBea/hcxdumpool/discussions/526

Information: missing frames!
This dump file does not contain enough EAPOL M1 frames.
It always happens if the capture file was cleaned or it could happen if filter options are used during capturing.
That makes it impossible to calculate nonce-error-correction values.
https://hashcat.net/forum/thread-6361.html
Duration was a way too short to capture enough additional information.
```

Сводка hcxrcapngtool: кадры M1–M4 на месте, записана 1 EAPOL-пара; отдельной строки PMKID нет

```
~: zsh — Konsole
Новая вкладка  Разделить окно
Копировать  Вставить  Поиск...

EAPOL M3IE2 (authorized - ANONCE from M3): 1
packet read error.....: 1

Information: limited dump file format detected!
This file format is a very basic format to save captured network data.
It is recommended to use PCAP Next Generation dump file format (or pcapng for short) instead. The PCAP Next Generation dump file format is an attempt to overcome the limitations of the currently widely used (but very limited) libpcap (cap, pcap) format.
https://www.wireshark.org/docs/wsug_html_chunked/AppFiles.html#ChAppFilesCaptureFilesSection
https://github.com/pcapng/pcapng

Information: radiotap header is missing!
Radiotap is a de facto standard for 802.11 frame injection and reception. The radiotap header format is a mechanism to supply additional information about frames, from the driver to userspace applications.
https://www.radiotap.org/

Warning: too many deauthentication/disassociation frames detected!
That can cause that an ACCESS POINT change channel, reset EAPOL TIMER, renew ANONCE and set PMKID to zero. This could prevent to calculate a valid EAPOL MESSAGE PAIR, to get a valid PMKID or to decrypt the traffic.

Information: missing frames!
This dump file does not contain undirected probe request frames.
An undirected probe request may contain information about the PSK. It always happens if the capture file was cleaned or it could happen if filter options are used during capturing.
That makes it hard to recover the PSK.
https://github.com/ZerBea/hcxdumpool/discussions/526

Information: missing frames!
This dump file does not contain enough EAPOL M1 frames.
It always happens if the capture file was cleaned or it could happen if filter options are used during capturing.
That makes it impossible to calculate nonce-error-correction values.
https://hashcat.net/forum/thread-6361.html
Duration was a way too short to capture enough additional information.

session summary
```

Предупреждение о деаут-флуде («set PMKID to zero») и итоговый хеш вида WPA\*02\* — это handshake, не PMKID

Строгий разбор показал более тонкую картину, чем оптимистичный отчёт aircrack-ng:

- **Валидный 4-way handshake — ЕСТЬ.** Пойманы кадры M1–M4, «EAPOL pairs written to 22000 hash file: 1». Хеш начинается с WPA\*02\* — код 02 в формате hashcat 22000 означает handshake.
- **Пригодного PMKID — НЕТ.** В сводке нет ни строки PMKID, ни хеша WPA\*01\*. hcxrcapngtool предупреждает: «too many deauthentication frames ... set PMKID to zero» — избыточный деаут-флуд заставил точку обнулить PMKID. aircrack-ng засчитал наличие поля, строгая проверка — нет.

Проверка «свой ли захват»: в хеше есть 52542d47504f4e2d45443838 — это HEX от RT-XXXX-XXXX, а 10a3b8f0ed89 — MAC роутера. Рукопожатие снято с целевой точки.

## 6. Результаты

| Метод / этап                                    | Результат | Почему                                             |
|-------------------------------------------------|-----------|----------------------------------------------------|
| Активный PMKID (hcxdumpptool, 45 с)             | Провал    | Активная инъекция не проходит через VM + RTL8812AU |
| Активный PMKID (hcxdumpptool, 100 с)            | Провал    | Увеличение окна не помогло                         |
| Контроль: PMKID с телефона ([тестовый телефон]) | Провал    | Эталон тоже не снялся → виноват стенд, не роутер   |
| Handshake, деаут mdk4 (20 с)                    | Провал    | Короткое окно, клиент не переподключился           |
| Handshake, деаут aireplay (60 с) + реконнект    | Успех     | Пойман валидный 4-way handshake (WPA*02*)          |
| Usable PMKID (проверка hcxpcapngtool)           | Нет       | PMKID обнулён деаут-флудом; хеша WPA*01* нет       |

## 7. Выводы

- PMKID — необязательная функция.** Атака работает только если точка вкладывает непустой PMKID в кадр M1.
- Активный метод не пошёл в виртуалке.** hcxdumpptool в связке VirtualBox + RTL8812AU не смог провести активную ассоциацию — совпадает с его же предупреждением «no VMs».
- Контрольный эксперимент важнее удобного вывода.** Провал на телефоне-эталоне показал, что дело в стенде, и не дал ошибочно объявить роутер защищённым.
- Деаут-флуд обнуляет PMKID.** Пассивный захват с агрессивным деаутом дал handshake, но PMKID обнулится. Для чистого PMKID нужен «мягкий» захват — без деаута, на естественной ассоциации клиента.
- Handshake на этом стенде берётся надёжно.** Пассивный airodump + прицельный aireplay-деаут отработали, как и в Лаб 1.
- Вопрос PMKID-уязвимости роутера не закрыт начисто.** Не «защищён», а «не проверено чисто»: нужен мягкий deauth-free заход для необнулённого PMKID.
- Защита в итоге держится на пароле.** Даже добыв материал, стойкость упирается в пароль: случайный заводской 10-символьный ключ офлайн-перебору практически не поддаётся.

## 8. Что дальше

- «Мягкий» захват PMKID без деаута (airodump на канале 3 + ручное подключение телефона) — чтобы окончательно ответить, отдаёт ли роутер рабочий PMKID.
- WPS / Pixie Dust — следующая поверхность атаки по роадмапу.
- Полная цепочка на эталоне: снять чистый PMKID с телефона (пароль 123456789 есть в rockyou) и провести PMKID → hashcat -m 22000 → KEY FOUND как демонстрацию.